HIPAA & GDPR Compliance Templates

Standard Legal Frameworks for Data Protection

This document provides standardized, legally grounded templates for a **HIPAA Business Associate Agreement (BAA)** and a **GDPR Data Processing Agreement (DPA)**. These frameworks represent core regulatory requirements for cloud service providers, healthcare operators, and software vendors handling sensitive data in 2026.

DOCUMENT 1: BUSINESS ASSOCIATE AGREEMENT (HIPAA BAA)

This Agreement is entered into by and between the **Covered Entity** and the **Business Associate**.

1. Definitions

- **Business Associate** shall generally have the same meaning as the term 'business associate' at 45 CFR 160.103.
- **Covered Entity** shall generally have the same meaning as the term 'covered entity' at 45 CFR 160.103.
- **Protected Health Information (PHI)** shall have the same meaning as the term 'protected health information' at 45 CFR 160.103, limited to the information created or received by Business Associate from or on behalf of Covered Entity.

2. Obligations and Activities of Business Associate

- **Permitted Uses:** Business Associate agrees to not use or disclose PHI other than as permitted or required by the Agreement or as required by law.
- **Safeguards:** Business Associate agrees to use appropriate administrative, physical, and technical safeguards to prevent use or disclosure of the PHI other than as provided for by this Agreement.
- **Mitigation:** Business Associate agrees to mitigate, to the extent practicable, any harmful effect that is known to Business Associate of a use or disclosure of PHI by Business Associate in violation of the requirements of this Agreement.
- **Breach Reporting:** Business Associate agrees to report to Covered Entity any use or disclosure of the information not provided for by its Agreement of which it becomes aware, including breaches of unsecured protected health information as required by 45 CFR 164.410, without unreasonable delay and in no event later than 60 days.

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.

3. Term and Termination

Upon Covered Entity's knowledge of a material breach by Business Associate, Covered Entity shall provide an opportunity for Business Associate to cure the breach. If Business Associate does not cure the breach within thirty (30) days, Covered Entity may immediately terminate this Agreement.

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.

DOCUMENT 2: DATA PROCESSING AGREEMENT (GDPR DPA)

This Data Processing Agreement (DPA) forms part of the Master Service Agreement ('Agreement') between the **Data Controller** and the **Data Processor**.

1. Scope and Processing Framework (Article 28)

The Data Processor shall only process Personal Data on documented instructions from the Data Controller, including with regard to transfers of personal data to a third country or an international organization, unless required to do so by European Union or Member State law.

2. Confidentiality and Technical Security (Article 32)

- **Personnel:** The Data Processor ensures that persons authorized to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality.
- **Technical Measures:** Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing, the Processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk.

3. Sub-processors

The Processor shall not engage another processor (Sub-processor) without prior specific or general written authorization of the Controller. In the case of general written authorization, the Processor shall inform the Controller of any intended changes concerning the addition or replacement of other processors.

4. Data Subject Rights & Audit Assistance

The Processor shall assist the Controller by appropriate technical and organizational measures, insofar as this is possible, for the fulfillment of the Controller's obligation to respond to requests for exercising the data subject's rights laid down in Chapter III of the GDPR.

5. Data Breach Notification

The Data Processor shall notify the Data Controller without undue delay, and in any event no later than **72 hours**, after becoming aware of a personal data breach.

IN WITNESS WHEREOF, the parties have executed these Standard Frameworks.

For Covered Entity / Data Controller:	**For Business Associate / Data Processor:**
_____	_____
Authorized Signature	Authorized Signature
Name: _____	Name: _____

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.

Title: _____ Title: _____

Date: _____ Date: _____

This is for informational purposes only. For medical advice or diagnosis, consult a professional. AI responses may include mistakes.